

GUÍA METODOLÓGICA DETALLADA: ENCUESTA CIBERSEGURIDAD IA

Directrices para respondentes y analistas

Versión: 1.0

Clasificación: Público - Implementación

Fecha: Enero 2026

INTRODUCCIÓN

Esta guía proporciona **instrucciones detalladas** para:

1. **Respondentes:** Cómo completar encuesta honesta y precisa
2. **Analistas:** Cómo validar, analizar e interpretar respuestas

PARTE I: GUÍA PARA RESPONDENTES

Perfil Ideal del Respondente

Quién debe responder:

- ☒ CISO o equivalente (Chief Information Security Officer)
- ☒ Responsable ciberseguridad IA (si existe rol dedicado)
- ☒ Auditor interno especializado en IA/seguridad
- ☒ Responsable de gobernanza tecnológica

Quién NO debe responder:

- ☒ Personal técnico sin visión estratégica
- ☒ Terceros sin acceso a información completa
- ☒ Respondentes que desconozcan IA/seguridad

Principios Fundamentales

1. **Honestidad:** Responde verazmente, no "idealmente"
2. **Contexto actual:** Describe estado HOY, no planes futuros
3. **Evidencia:** Basa respuestas en documentación/evidencia, no suposiciones
4. **Precisión:** Si dudas, elige opción conservadora (más baja)

Cómo Responder: Escala Likert 1-5

ESCALA INTERPRETACIÓN:

- 1 = NO IMPLEMENTADO
 - No existe, completamente ausente, funcionalidad 0%
 - Ejemplo: "No tenemos política IA formal"
 - Selecciona 1
- 2 = INICIADO
 - Borrador, concepto, piloto, <25% implementado
 - Ejemplo: "Estamos desarrollando política IA"
 - Selecciona 2
- 3 = INTERMEDIO
 - Parcialmente implementado, 50% funcional, ad-hoc
 - Ejemplo: "Política aprobada pero no completamente implementada"
 - Selecciona 3
- 4 = MADURO
 - Implementado, 80%+ funcional, proceso formal
 - Ejemplo: "Política implementada, monitoreo regular"
 - Selecciona 4
- 5 = OPTIMIZADO
 - Completamente implementado, continuo, automatizado, lecciones aprendidas
 - Ejemplo: "Política implementada, revisión anual, integrada en estrategia"
 - Selecciona 5

REGLA DE ORO:

Si es dudoso entre dos niveles, selecciona el MÁS BAJO
(ejemplo: entre 3 y 4, elige 3)

Contextualización por Módulo

Módulo 1 (Gobernanza): Pregunta sobre ESTRUCTURA + DOCUMENTACIÓN

- Busca: Políticas, roles definidos, presupuesto, auditorías
- NO busca: Implementación operativa de controles

Módulo 2 (Activos): Pregunta sobre VISIBILIDAD + INVENTARIO

- Busca: ¿Sabes qué sistemas IA tienes? ¿Son críticos?
- NO busca: Implementación de seguridad

Módulo 3 (Vulnerabilidades): Pregunta sobre IDENTIFICACIÓN

- Busca: ¿Pruebas para encontrar problemas?
- NO busca: Remediación

Módulo 4-7: Pregunta sobre DEFENSAS TÉCNICAS IMPLEMENTADAS

- Busca: Controles activos, funcionales, auditables

Módulo 8: Pregunta sobre MITRE ATLAS ESPECÍFICAMENTE

- Busca: ¿Conoces amenazas IA? ¿Tienes defensas?

Módulo 9-13: Pregunta sobre PROCESOS ESPECIALIZADOS

- Busca: Conformidad regulatoria, training, continuidad negocio, riesgo

Errores Comunes y Cómo Evitarlos

Error	Descripción	Corrección
Respuesta "idealizada"	Describes cómo DEBERÍAS estar, no cómo estás	Sé honesto. El objetivo es diagnóstico preciso.
Confundir términos	¿Es SIEM = "security monitoring"?	Lee definiciones en glosario abajo.
Scope no claro	¿Aplica a toda empresa o solo IA?	Enfoca SOLO en sistemas IA críticos.
Sobreestimar madurez	Creas que tienes 4 cuando es realmente 2	Busca EVIDENCIA (logs, políticas, audits).
No leer preguntas	Respondes por inercia	Lee cada pregunta completa + opciones.

PARTE II: GUÍA PARA ANALISTAS

Protocolo de Validación de Datos

Paso 1: Validación Formato

Para cada respuesta:

- ✓ Escala 1-5 (no valores fuera rango)
- ✓ Campos obligatorios no vacíos
- ✓ Email válido (si aplica)
- ✓ Sector válido (7 opciones permitidas)
- ✓ Tamaño válido (PYME/Mediana/Grande)

Rechazo: Si <10% de preguntas completadas, descartar respuesta

Paso 2: Validación Lógica

Inconsistencias sospechosas:

M5.Q1 (SIEM) = 1 (No existe)
pero M5.Q3 (MTTD) = 5 (< 2 horas)
→ Marcar para validación manual

M1.Q4 (Presupuesto) = 5 (>€500k)
pero M4-M7 (Defensas) = promedio 2
→ Posible error respondente o gestión ineficiente

Validación manual: Si 3+ inconsistencias, contactar respondente

Paso 3: Detección Outliers

Percentiles:

- Respondente con score 92/100 en todas preguntas → Revisión (posible gaming)
- Respondente con patrón 1-2-1-2 alternado → Revisión (posible no comprensión)
- Respondente con todo 5s → Posible llenado rápido, revisar

Paso 4: Análisis de Confianza

Indicadores de respuesta de confianza ALTA:

- ✓ Tiempo de respuesta 30-50 min (promedio 38 min)
- ✓ Observaciones cualitativas detalladas (>200 caracteres)
- ✓ Variabilidad en scores (no todos 1s o todos 5s)
- ✓ Coherencia lógica entre módulos relacionados

Indicadores de confianza BAJA:

- x Tiempo <15 min (demasiado rápido)
- x Tiempo >90 min (posible sesiones múltiples)
- x Observaciones ausentes o genéricas
- x Patrón de respuesta monótono

PARTE III: CÁLCULO DE INDICADORES

Cálculo IGM (Índice Gestión Madurez)

FÓRMULA:

$$\text{IGM} = (\text{Sum}(\text{M1.Q1 a M13.Q4})) / (\text{Total_Preguntas} \times 5) \times 100$$

Donde:

- Numerador: Suma de todas 52 respuestas (1-5 cada una)
- Denominador: 52 preguntas × 5 (máximo posible)
- Multiplicador: 100 (convertir a escala 0-100)

EJEMPLO:

$$\text{Org X: Suma} = 218 / (52 \times 5) \times 100 = 218 / 260 \times 100 = 83.8/100$$

Conversión IGM a Categoría

Score IGM	Categoría	Descripción	Acción
81-100	Muy Fuerte	Defensas maduras, detección continua	Mantener + mejorar ROI
61-80	Fuerte	Defensas operativas, plan mejora en progreso	Acelerar roadmap
41-60	Moderado	Defensas básicas, brechas identificadas	Inversión urgente 12 meses
21-40	Débil	Defensas insuficientes, riesgos críticos	Intervención inmediata 3-6 meses
0-20	Crítico	Sin defensas significativas	Regulador + gestión crisis

Sub-scores por Función NIST

GOVERN = (M1 + M10 promedio) × 20
→ Gobernanza + cumplimiento regulatorio

MAP = (M2 + M9 promedio) × 20
→ Mapeo activos + supply chain

MEASURE = (M5 + M8 promedio) × 20
→ Detección + defensa ATLAS

MANAGE = (M6 + M12 + M13 promedio) × 20
→ Respuesta + continuidad + riesgo

PARTE IV: ANÁLISIS ESTADÍSTICO

Análisis Descriptivo

Por cada métrica (M1.Q1 a M13.Q4):

1. Media aritmética
2. Mediana
3. Desviación estándar
4. Mínimo - Máximo
5. Percentiles (P25, P50, P75)
6. Distribución (% respondentes por nivel 1-5)

Benchmarking Sectorial

Agrupar por:

- Sector (7 grupos)
- Tamaño (3 grupos)
- Combinación sector × tamaño (21 grupos)

Calcular para cada grupo:

- Media IGM
- Mediana IGM
- Desviación estándar
- Top 3 fortalezas (score más alto)
- Top 3 debilidades (score más bajo)

Análisis Correlación

Investigar correlaciones:

1. IGM vs. Incidentes IA (si datos disponibles)
→ Validar predictibilidad
2. M2.1 (Score Madurez) vs. Presupuesto (02)
→ ¿Mayor presupuesto = mayor madurez?
3. M1.Q2 (CISO dedicado) vs. IGM total
→ ¿CISO dedicado correlaciona con madurez?
4. M11 (Training) vs. Incidentes
→ ¿Training reduce incidentes?

Reportar: Coeficiente Pearson (r), p-value, interpretación

PARTE V: INTERPRETACIÓN HALLAZGOS

Patrón 1: Fortaleza Sectorial

Ejemplo: Sector Financiero IGM = 72/100 vs. Media España 54/100

Interpretación:

- Financiero tiene madurez defensiva 33% superior
- Posible: Regulación más estricta, presupuesto mayor, talento concentrado

Recomendación:

- Best practice transfer: Financiero → otros sectores
- Crear programa peer learning entre CISOs similares

Patrón 2: Brecha PYME

Ejemplo: Grande 68/100 vs. PYME 38/100 (diferencia 30 puntos)

Interpretación:

- PYME son 3.5× más vulnerables
- Posible: Presupuesto limitado, no talento especializado

Recomendación:

- Programa subsidios SIEM pequeña empresa
- Shared services ciberseguridad IA

Patrón 3: Gap en Módulo Específico

Ejemplo: M8 (ATLAS) = 25/100 vs. M7 (Acceso) = 68/100

Interpretación:

- Defensas genéricas OK, pero defensas IA-specific débiles
- Posible: No conocen MITRE ATLAS, no priorizan

Recomendación:

- Campaña conciencia ATLAS nacional
- Requisa AESIA: implementar defensas ATLAS específicas

PARTE VI: REPORTES DE SALIDA

Reporte Personalizado (por Respondente)

Estructura:

1. Portada (org, fecha, confidencial)
2. Score IGM + categoría
3. Percentil vs. pares
4. Heatmap 13 módulos
5. Top 5 fortalezas
6. Top 5 debilidades
7. Benchmarking sector
8. Roadmap 12 meses
9. Contactos peer learning
10. Metodología (2 págs)

Formato: PDF 15-20 págs

Distribución: Email confidencial CISO respondente

Reporte Benchmark Nacional

Estructura:

1. Resumen ejecutivo (2 págs)
 - Media nacional: 54/100
 - Rango: 18-92
 - Gráfico distribución
2. Hallazgos clave (10 págs)
 - Brecha madurez IA
 - Disparidad sectorial
 - Brecha PYME-Grande
 - Deficiencia detección
 - Cumplimiento regulatorio
3. Benchmarking (8 págs)
 - Tablas sector x tamaño
 - Top orgs (liderazgo)
 - Bottom orgs (urgencia)
 - Gráficos comparativos
4. Recomendaciones (5 págs)
 - Inversión pública estimada
 - Política pública sugerida
 - Best practices identificadas
5. Apéndices (5 págs)
 - Metodología GQM+PRAGMATIC
 - Definiciones
 - Bibliografía

Formato: PDF 30 págs + CSV anonimizado

Distribución: Pública (AESIA, INCIBE, web)

GLOSSARIO DE TÉRMINOS

Término	Definición
AI Act	Regulación EU 2024/1689 sobre IA de alto riesgo
ATLAS	MITRE Adversarial Threat Landscape for AI Systems (15 tácticas)
CISO	Chief Information Security Officer
FAIR	Factor Analysis of Information Risk (modelo cuantitativo)
MTTD	Mean Time To Detect (tiempo promedio detección)
NIS2	Directiva EU 2022/2555 sobre seguridad redes críticas
PRAGMATIC	Criterios para métricas accionables (9 dimensiones)
RGPD	Regulación General Protección Datos (EU)
SIEM	Security Information Event Management
UEBA	User Entity Behavior Analytics

Guía Metodológica Preparada: Enero 2026

Versión: 1.0

Clasificación: Público - Implementación